



PROJECT TO CHOOSE FROM

CYBERSECURITY LECTURE, SUMMER SEMESTER, 2026

KRISTOF WERLING

SUMMARY

#	Project Title	Short Description
1	Maximum Security vs. Maximum Resilience	Investigate whether SMEs should strive for maximum security or maximum resilience, and develop a resilience-first cybersecurity model aligned with ISO 27001, NIS2, and the CRA.
2	How Can Resilience Be Proven?	Explore how organizational resilience can be demonstrated through evidence and how auditors could assess resilience in practice.
3	Can AI Think Like an Auditor?	Develop and evaluate the idea of using AI to emulate an auditor's reasoning, identify findings, and suggest evidence requirements.
4	Cybersecurity without Enterprise Resources	Design practical approaches that allow SMEs to address enterprise-level cybersecurity expectations despite limited resources.
5	Awareness After Phishing	Critically assess traditional phishing awareness training and propose more effective alternatives supported by research and regulatory requirements.
6	AuditorGPT – Think Like an Auditor	Build a prototype that generates auditor questions, expected evidence, and potential findings from a given scenario description.
7	Resilience Prioritizer	Develop a decision-support tool that prioritizes cybersecurity measures based on risks, available budget, and limited resources.
8	CRA Evidence Passport	Create a prototype for managing CRA-related evidence such as SBOMs, vulnerabilities, incident reports, and update information.

MAXIMUM SECURITY VS. MAXIMUM RESILIENCE

Background	• Organizations are often encouraged to pursue "maximum security." • SMEs rarely possess the resources required to achieve this goal. • The course introduced the concept of resilience-first cybersecurity.	
Objectives	• Investigate the concepts of security and resilience. • Identify resilience aspects within ISO 27001, NIS2, and the CRA. • Develop an alternative resilience-oriented framework. • Apply the framework to a realistic SME scenario.	
Deliverables	• Short report (8–10 pages) • Framework description	• Example application to an SME • Presentation of findings
Expected Outcome	A practical model showing how SMEs can maximize resilience instead of pursuing unattainable security perfection.	

HOW CAN RESILIENCE BE PROVEN?

Background	• Auditors rely heavily on evidence. • Security controls are often easy to demonstrate. • Organizational resilience is more difficult to assess objectively.	
Objectives	• Investigate the concept of evidence in audits. • Analyze how ISO 27001 currently demonstrates effectiveness. • Identify challenges in proving resilience. • Propose resilience indicators and evidence sources.	
Deliverables	• Literature review • Proposed resilience evidence model	• Example evidence catalogue • Presentation of findings
Expected Outcome	A structured approach enabling organizations to demonstrate resilience during audits.	

CAN AI THINK LIKE AN AUDITOR?

Background	• Large Language Models increasingly support knowledge work. • Auditing involves experience-based reasoning. • The course introduced the auditor mindset.	
Objectives	• Analyze how auditors identify findings. • Model auditor reasoning processes. • Investigate whether AI can reproduce this reasoning. • Evaluate strengths and limitations.	
Deliverables	• Conceptual model • Example prompts	• Sample analyses • Reflection on risks and limitations
Expected Outcome	A critical assessment of AI as a future audit assistant.	

CYBERSECURITY WITHOUT ENTERPRISE RESOURCES

Background	• SMEs face enterprise-grade expectations. • Most organizations lack enterprise budgets and expertise. • Compliance requirements continue to increase.	
Objectives	• Identify key cybersecurity expectations. • Analyze barriers faced by SMEs. • Develop compensating approaches. • Propose a practical prioritization model.	
Deliverables	• Gap analysis • SME-oriented framework	• Prioritization recommendations • Presentation of results
Expected Outcome	Actionable guidance enabling SMEs to improve cybersecurity despite limited resources.	

AWARENESS AFTER PHISHING

Background	• Recent studies question the effectiveness of traditional phishing simulations • Awareness remains a requirement in multiple regulations. • Organizations continue investing heavily in existing approaches.	
Objectives	• Analyze current awareness practices. • Review relevant scientific studies. • Identify awareness requirements in ISO 27001 and NIS2. • Design alternative awareness concepts.	
Deliverables	• Literature review • Regulatory mapping	• Improved awareness concep • Example implementation plan
Expected Outcome	Evidence-based recommendations for more effective cybersecurity awareness programs.	

AUDITORGPT – THINK LIKE AN AUDITOR

Background	• Auditors ask questions, seek evidence, and identify findings. • Generative AI could support this process. • The course explored auditor thinking patterns.	
Objectives	• Develop an AI-assisted auditing prototype. • Generate likely auditor questions. • Suggest expected evidence. • Identify potential findings.	
Deliverables	• Working prototype (CLI or Web) • Prompt design documentation	• Five demonstration scenarios • Reflection on limitations
Expected Outcome	An initial "AuditBuddy" capable of supporting audit preparation activities.	

RESILIENCE PRIORITIZER

Background	• Organizations cannot implement every possible security control. • Resources must be allocated strategically. • Resilience requires informed trade-offs.	
Objectives	• Design a prioritization approach. • Incorporate risks, budget, and available effort. • Recommend appropriate measures. • Estimate resilience improvements.	
Deliverables	• Prototype implementation • Prioritization methodology	• Example scenarios • User documentation
Expected Outcome	A practical tool supporting resilience-focused decision making.	

CRA EVIDENCE PASSPORT

Background	• The Cyber Resilience Act requires extensive evidence. • Many organizations struggle to understand documentation obligations. • Evidence is often scattered across multiple systems.	
Objectives	• Identify relevant CRA evidence categories. • Design a structured evidence repository. • Develop a prototype implementation. • Assess completeness and usability.	
Deliverables	• Prototype application • Data model	• Example dataset • Demonstration and evaluation
Expected Outcome	A digital evidence passport supporting CRA readiness and regulatory inspections.	